

TAREA AFI03

Consideraciones Cloud

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Consideraciones de la Nube	3
Respuesta 1	4
Referencias bibliográficas.	7

Detalles de la tarea de esta unidad

Caso práctico

La empresa de María va a contratar servicios de cloud para poder almacenar determinados datos de la empresa, están barajando distintas ofertas de los proveedores.

Tienen la preocupación de llegado el caso de un Incidente de seguridad si serán capaces de poder realizar los análisis forenses correspondientes. También tienen la duda de qué pasará con esos datos y si serán accesibles.

Para ello solicitan la ayuda de María para internamente saber cómo deben de gestionar el contrato con el proveedor de servicios.

Apartado 1: Consideraciones de la Nube

Esta tarea es eminentemente teórica, para realizarla deberás **repasar los conceptos previamente explicados e investigar** sobre la protección de datos y regulaciones.

Cuando una empresa contrata un servicio de cloud o nube, ¿qué consideraciones tiene que tener en cuenta y más teniendo en cuenta los aspectos de futuros forenses en este entorno?

- ¿Qué sucede si tenemos que hacer la investigación en un entorno o máquina que tenemos subcontratado a un proveedor que tiene los servicios en nube?
- ¿Qué obligaciones y responsabilidades tiene el cliente que contrata servicios de cloud a efectos de protección del dato?
- ¿Qué es un servicio transparente de cloud? ¿Qué consecuencias tiene un servicio opaco?
- ¿Cómo puedo recuperar mis datos? Y si son de carácter personal (art 20 RGPD)
- ¿Qué garantías debo pedir al proveedor de servicios de cloud para evitar tener problemas al hacer un forense en el entorno de cloud o nube?
- ¿Puedo pedir al proveedor que se convierta en el responsable de mis datos al tenerlos alojados en su nube?

Respuesta 1

Como hemos visto en la unidad, cuando contratamos un servicio en la nube, lo primero de todo será realizar un pequeño análisis del tipo de servicio que queremos contratar:

- **SaaS** (Software as a service): Buscamos productos finales o herramientas en la nube y debemos tener en cuenta que el **proveedor** es el responsable de administrar el contenido y los datos de dicho software.
- **IaaS** (Infrastructure as a Service): Nuestro almacenamiento y procesamiento en Bruto se encuentra en la nube y por lo tanto toda nuestra infraestructura está alojada en ella y debemos tener en cuenta que el **proveedor** es el propietario de dicha infraestructura, pero nuestra **empresa**, sigue siendo parcialmente responsable de la integridad de los datos, las aplicaciones y el sistema operativo que se utiliza.
- **PaaS** (Platform as a service) un camino intermedio en el que nuestra **empresa** como propietaria de la plataforma es responsable de los datos que contiene, pero no de la red, los servidores o el sistema operativo de los mismos.

Una vez tenemos claro el tipo de servicio, procedemos a realizar un estudio de los diferentes tipos de Cloud:

- Cloud **Pública**: Si vamos a contratar a un proveedor de servicios el almacenamiento de nuestros datos fuera de la empresa, para acceder a software, redes y servidores en cualquier momento desde cualquier dispositivo.
- Cloud **Privada**: Si únicamente vamos a implementar nuestros sistemas y aplicaciones en nuestra infraestructura alojada en nuestros servidores, pero basándonos en la nube.
- Cloud **Híbrida**: Si queremos almacenar los datos confidenciales en nuestra propia nube privada, pero permitir que el resto de la infraestructura se almacene en la nube pública.

Una vez tenemos claro el tipo de servicio y el tipo de Cloud para el mismo el siguiente punto que debemos considerar será el tratamiento legal de nuestra infraestructura y nuestros datos y para ello debemos tener en cuenta que al migrar a la nube, aunque se puede tener un ahorro en administración de hardware, el análisis forense se vuelve un problema que debe revisarse antes de implementar estos servicios.

Las principales consideraciones son:

- **Localización física y legal**: Es vital conocer la ubicación física de los servidores, ya que la legislación vigente en esa localización determinará la validez de la evidencia en un juicio.
- **Jurisdicción**: Factores como el **GDPR de la UE** o la **Ley CLOUD de EE. UU.** condicionan la propiedad, responsabilidad y los procesos de extracción de evidencias.

- **Proveedor y permisos:** Se debe anotar el tipo de servicio, el proveedor y la legislación aplicable según la ubicación. Es necesario solicitar permiso al proveedor para realizar el forense según el servicio contratado.
- **Falta de control:** En nubes públicas, no tendremos un control total sobre si terceros (el propio proveedor o gobiernos) manipulan los datos.
- ¿Qué sucede si tenemos que hacer la investigación en un entorno o máquina que tenemos subcontratado a un proveedor que tiene los servicios en nube?

Cuando tengamos que realizar una investigación forense en una máquina o entorno subcontratado a un proveedor de servicios en la nube, el proceso se vuelve significativamente más **complejo a nivel logístico y legal**.

Por un lado, debemos tener en cuenta, como hemos visto antes, que tendremos una posible **pérdida de control**, propiedad y seguridad de los datos, haciendo mas compleja la extracción de evidencias validas y por otro lado, tendremos una **mayor complejidad** a la hora de tratar la evidencia de una manera legal, puesto que la legislación vigente en el lugar donde se encuentra el servidor es lo que determina si las pruebas extraídas serán admisibles en un juicio.

- ¿Qué obligaciones y responsabilidades tiene el cliente que contrata servicios de cloud a efectos de protección del dato?

Influirá el tipo de servicio contratado:

Infraestructura como Servicio (IaaS): El cliente es parcialmente responsable de la integridad de los datos.

Plataforma como Servicio (PaaS): El cliente es el responsable directo de los datos y de las aplicaciones.

Software como Servicio (SaaS): El cliente es el responsable de los datos y el proveedor de la infraestructura y el software que lo contiene.

- ¿Qué es un servicio transparente de cloud? ¿Qué consecuencias tiene un servicio opaco?

En relación con el control de la localización de nuestros datos, un servicio de cloud puede ser auditable o **transparente** (en el sentido de la palabra inglesa accountable) cuando el contratista puede reclamar información precisa de dónde, cuándo y quién ha almacenado o procesado sus datos (dentro de los recursos propios del proveedor o de la cadena de subcontrataciones), y en qué condiciones de seguridad se ha producido. En otro caso, nos encontraremos con un servicio **opaco** al usuario, en el que éste no tiene opción alguna de obtener información precisa de qué ha ocurrido con sus datos ni herramientas para auditar el servicio que se le está proporcionando y en el que su propia información escapa a su control. (*Fuente: Agencia Española de Protección de Datos | AEPD*)

- ¿Cómo puedo recuperar mis datos? Y si son de carácter personal (art 20 RGPD)

Cuando los datos son de carácter personal, el proceso se rige por el **Reglamento General de Protección de Datos (RGPD)** de la UE, el cual condiciona la propiedad y responsabilidad de la información y como indica el artículo 20:

El interesado tendrá derecho a recibir los datos personales que le incumban, que haya facilitado a un responsable del tratamiento, en un formato estructurado, de uso común y lectura mecánica, y a transmitirlos a otro responsable del tratamiento sin que lo impida el responsable al que se los hubiera facilitado, cuando:

- a) El tratamiento esté basado en el consentimiento o en un contrato.
- b) El tratamiento se efectúe por medios automatizados.

- ¿Qué garantías debo pedir al proveedor de servicios de cloud para evitar tener problemas al hacer un forense en el entorno de cloud o nube?

Para asegurar que una investigación sea **verificable, auditable y reproducible**, y que las pruebas sean admisibles ante un tribunal, es fundamental exigir las siguientes garantías al proveedor de cloud:

- Transparencia sobre la ubicación física del dato
 - Derecho de acceso a evidencias
 - Provisión de telemetría y registros (logs)
 - Certificaciones de cumplimiento regulatorio
-
- ¿Puedo pedir al proveedor que se convierta en el responsable de mis datos al tenerlos alojados en su nube?

La respuesta desde una perspectiva legal y técnica es que la responsabilidad suele ser compartida o recaer principalmente en el cliente, dependiendo del modelo de servicio.

Aunque en base a lo aprendido, todo esto tendría que ser analizado por un consultor legal.

Referencias bibliográficas.

Agencia Española de Protección de Datos - <https://www.aepd.es/guias/guia-cloud-clientes.pdf>

Artículo 20 UE RGDP - <https://www.privacy-regulation.eu/es/20.htm>